

Evolution Nord – Centre de formation (Lille)

Réalisé par : Esra ATIA

Date : 17 juin

Version : 1.0 – Document final

1. Contexte

Dans le cadre du stage chez Evolution Nord, l'inspection de l'Active Directory a révélé :

- Des comptes utilisateurs et administratifs mal segmentés
- Des droits excessifs pour certains profils
- Une absence de documentation des habilitations

Problématique : Risque de sécurité interne, absence du principe du moindre privilège, impossibilité de justifier les accès en cas d'audit.

2. Objectifs

- Analyser les droits existants
 - Supprimer les privilèges superflus
 - Créer des groupes AD basés sur les rôles
 - Documenter les habilitations
 - Mettre en place une procédure d'audit régulier
-

3. Périmètre

Composants concernés :

- Active Directory (contrôleur de domaine : EVO-NORD-DC01)
- Groupes de sécurité
- Stratégies de groupe (GPO)
- Dossiers partagés (\EVONORD, NAS 192.168.1.45)
- Imprimantes et applications métier

Groupes d'utilisateurs identifiés :

Groupe	Description
Eleves	Apprenants en formation
Formateurs	Intervenants pédagogiques
Equipe interne	Personnel administratif et support
Administrateur	Maintenance et gestion AD

4. Inventaire des comptes et droits existants (avant audit)

4.1 Comptes recensés

Type de compte	Nom d'utilisateur	Membre de	Droits observés
Eleve	eleve001 à eleve045	Domain Users	Accès à tous les partages réseau
Formateur	formateur001 à formateur012	Domain Users, Remote Desktop Users	Modification des dossiers élèves, accès serveur de fichiers
Equipe interne	secretariat01, compta01, direction01	Domain Admins	Création/suppression d'utilisateurs

Administrateur	Esra ATIA	Enterprise Admins, Domain Admins	Tous les droits
----------------	-----------	-------------------------------------	-----------------

4.2 Droits excessifs constatés

Constat	Gravité	Comptes concernés
Éléves en lecture/écriture sur les dossiers d'autres élèves	Élevée	45 comptes élèves
Équipe interne membre du groupe Domain Admins	Critique	3 comptes
Formateurs ayant droits d'installation logicielle	Moyenne	12 comptes
Absence de séparation entre compte utilisateur et compte admin	Critique	Tous les comptes équipe interne
Mot de passe non expiré pour comptes inactifs	Moyenne	22 comptes

5. Nouvelle structure des groupes AD (basée sur les rôles)

5.1 Groupes créés

Nom du groupe	Type	Membres	Niveau de privilège
---------------	------	---------	---------------------

Groupe_Eleves	Securite (Global)	Tous les eleves	Lecture seule sur dossiers partages formation
Groupe_Formateur s	Securite (Global)	Tous les formateurs	Lecture/ecriture sur dossiers pedagogiques
Groupe_EquipeInte rne	Securite (Global)	Personnel admin, compta, direction	Acces restreint par sous-dossier
Groupe_SupportTe ch	Securite (Global)	Techniciens	Gestion des impressions, reinitialisation mots de passe eleves
Groupe_AdminsRe streints	Securite (Universal)	Esra ATIA uniquement	Droits admin sauf domaine
Groupe_DomainAd mins	Securite (Universal)	Esra ATIA (compte dedie separe)	Admin complet (reserve urgence)

5.2 Correspondance roles → groupes

Role metier	Groupe AD attribue	Droits herites
Eleve	Groupe_Eleves	Lecture \\EVONORD\Ressources\Co urs

Formateur	Groupe_Formateurs	Lecture/ecriture \EVONORD\Ressources\Fo rmateurs, modification \EVONORD\Devoirs
Secretariat	Groupe_EquipeInterne	Lecture/ecriture \EVONORD\Admin (sauf salaires)
Comptabilite	Groupe_EquipeInterne + Groupe_Compta	Acces \EVONORD\Finance en lecture seule
Technicien	Groupe_SupportTech	Reinitialisation MDP eleves, acces imprimantes
Administrateur	Groupe_AdminsRestreints	Connexion serveurs, gestion GPO, audit
Administrateur urgence	Groupe_DomainAdmins	Tous droits (verrouille, MFA)

6. Mise en oeuvre technique

6.1 Actions realisees

Action	Detail	Statut
Retrait des eleves du groupe Domain Users par default	Creation d une OU Eleves avec GPO dediee	Fait

Retrait de l'équipe interne du groupe Domain Admins	Déplacement vers Groupe_EquipeInterne	Fait
Suppression des droits d'installation des formateurs	Suppression du groupe local Power Users sur les postes formateurs	Fait
Création d'un compte administrateur séparé pour Esra ATIA	Compte EA_admin_stage	Fait
Désactivation des comptes inactifs	Déplacement dans OU Comptes_Desactives	Fait

6.2 Configuration NTFS appliquée

Dossier	Groupe	Permission	Propagation
\\EVONORD\Ressources\Cours	Groupe_Eleves	Lecture	Ce dossier et sous-dossiers
\\EVONORD\Devoirs	Groupe_Eleves	Lecture/Ecriture (dossier personnel)	Objets enfants seulement
\\EVONORD\Formateurs	Groupe_Formateurs	Modification	Ce dossier et sous-dossiers
\\EVONORD\Admin\Salaire	Groupe_Equipe Interne	Aucun accès	Explicitement bloqué

\EVONORD\Admin\Salaires	Groupe_Compta	Lecture	Uniquement ce dossier
-------------------------	---------------	---------	-----------------------

7. Documentation des habilitations

7.1 Tableau des habilitations

Identifiant	Role	Groupe AD	Ressource	Type d'accès	Justification
HAB-001	Eleve	Groupe_Eleves	\EVONORD\Ressources\Cours	Lecture	Consultation supports pedagogiques
HAB-002	Eleve	Groupe_Eleves	\EVONORD\Devoirs[eleve]	Ecriture	Depot de travaux
HAB-003	Formateur	Groupe_Formateurs	\EVONORD\Formateurs	Lecture/Ecriture	Preparation cours
HAB-004	Formateur	Groupe_Formateurs	\EVONORD\Devoirs	Lecture	Correction travaux
HAB-005	Secretariat	Groupe_Equipelinterne	\EVONORD\Admin	Lecture/Ecriture	Gestion administrative
HAB-006	Comptabilite	Groupe_Compta	\EVONORD\Finance	Lecture	Facturation

HAB-007	Technicien	Groupe_Support Tech	Controleur AD	Reinitialisati on MDP	Support eleves
HAB-008	Administra teur	Groupe_Admins Restreints	Serveurs	Gestion GPO, audits	Maintenance
HAB-009	Admin urgence	Groupe_Domain Admins	Domaine complet	Tous droits	Recuperation crise

7.2 Matrice des droits

Ressource → Groupe ↓	Cours	Devoirs (eleve)	Devoir s (tous)	Format eurs	Admin	Financ e
Groupe_Elev es	Lecture	Ecritur e propre	Non	Non	Non	Non
Groupe_For mateurs	Lecture /Ecritur e	Non	Lectur e	Lecture /Ecritur e	Non	Non
Groupe_Equi pelInterne	Lecture	Non	Non	Lecture	Lectur e/Ecrit ure	Non
Groupe_Com pta	Non	Non	Non	Non	Non	Lecture

Groupe_Sup portTech	Lecture	Non	Non	Non	Lecture restreinte	Non
Groupe_Adm insRestreints	Lecture /Ecriture	Lecture /Ecriture	Lecture /Ecriture	Lecture /Ecriture	Lecture /Ecriture	Lecture

8. Procedure d audit regulier des habilitations

8.1 Periodicite

- Audit trimestriel automatise
- Revue annuelle avec la direction

8.2 Procedure formalisee

Etape 1 – Script d inventaire

Execution du script Get-ADUserHabilitations.ps1 tous les 3 mois.

Extrait de sortie :

```
text
```

```
=== RAPPORT HABILITATIONS - 17 JUIN ===
```

```
Groupes actifs : 6
```

```
Comptes actifs : 78
```

```
Comptes inactifs >90 jours : 3 (a desactiver)
```

```
Droits directs (hors groupe) detectes : 0
```

```
Membres de Domain Admins : EA_admin_stage uniquement
```

```
Derniere modification des groupes : 17/06 par Esra ATIA
```

Etape 2 – Verification manuelle

Controle d un echantillon de 5 habilitations par trimestre.

Etape 3 – Revue des comptes privileges

- Tous les membres de Groupe_AdminsRestreints et Groupe_DomainAdmins sont listes
- Justification ecrite conservee 1 an

Etape 4 – Correction

Suppression des droits excessifs dans les 48h suivant detection.

Etape 5 – Journalisation

Logs centralises dans \EVONORD\LogsRGPD\Habilitations.log

9. Information et validation

Acteur	Date	Retour	Validation
Equipe interne	17 juin	Reunion de 30 minutes	Valide
Formateurs	17 juin	Notification par email	Valide
Direction	17 juin	Presentation de la matrice	En attente de signature

Email type envoye :

Objet : Mise a jour de vos habilitations Active Directory

Date : 17 juin

Votre acces a ete modifie selon le principe du moindre privilege.

Consultez la matrice des droits jointe.

Pour toute anomalie : support@evolution-nord.fr

10. Bilan

Indicateur	Avant	Après
Comptes avec droits administrateur	5	1 + 1 urgence
Eleves accedant aux dossiers d autres eleves	Oui (45)	Non
Formateurs avec droits d installation	Oui (12)	Non
Documentation des habilitations	Aucune	Complete
Audit automatique des droits	Non	Script trimestriel

Resultat final :

- Gouvernance des droits amelioree
- Risque de privileges excessifs reduit
- Suivi des habilitations formalise
- Conformite avec les bonnes pratiques Active Directory